21.01 Encryption fundamentals

Encryption can be used as a routine procedure when storing data within a computing system. However, the focus in this chapter is on the use of encryption when transmitting data over a network.

There are three issues that will be considered in this chapter:

- is the encryption algorithm sufficiently robust to prevent the encrypted data being decrypted by some unauthorised third-party?
- how is it possible to ensure that a secret key remains secret?
- how can the receiver of a communication be sure who sent the communication?

The use of encryption is illustrated in Figure 21.01.The process starts with original data referred to as **plaintext**, whatever form it takes. The plaintext is encrypted by an encryption algorithm which makes use of a key. The product of the encryption is **ciphertext**, which is transmitted to the recipient. When the transmission is received it is decrypted using a decryption algorithm and a key to produce the original plaintext.

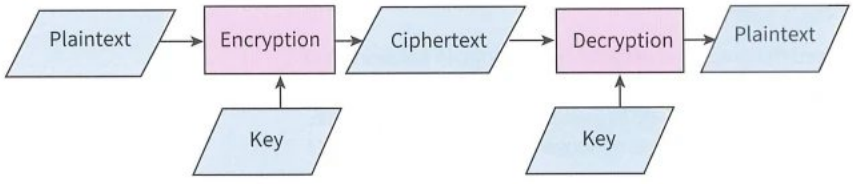


Figure 21.01 Overview of encryption and decryption

KEY TERMS

Plaintext: data before encryption

Ciphertext: the result of applying an encryption algorithm to data

Security concerns

There are a number of security concerns relating to a transmission.

- Confidentiality: Only the intended recipient should be able to decrypt the ciphertext.
- Authenticity: The receiver must be certain who sent the ciphertext.
- Integrity: The ciphertext must not be modified during transmission.
- Non-repudiation: Neither sender nor receiver should be able to deny involvement in the transmission.
- Availability: Nothing should happen to prevent the receiver from receiving the transmission.

This chapter will consider only confidentiality, authenticity and integrity.

The confidentiality concern arises because a message could be intercepted during transmission and the contents read by an unauthorised person. The concern about integrity reflects the fact that the transmission might be interfered with deliberately but also that there might be accidental corruption of the data during transmission.

Encryption methods

The fundamental principle of encryption is that the encryption algorithm must not be a secret: it must be in the public domain. In contrast, an encryption key must be secret.

However, there are two alternative approaches. One is **symmetric key encryption**, and the other is **asymmetric key encryption** also known as public key encryption.

KEY TERMS

Symmetric key encryption: one private key is held by both sender and receiver and is used for both encryption and decryption

Asymmetric key encryption: there is a public key and a private key one of which is used for encryption and the other for decryption

In symmetric key encryption there is just one key. This key is a secret shared by the sender and the receiver of a message. The sender uses the encryption algorithm together with the key to encrypt some plaintext. The receiver decrypts the ciphertext using the same key.

The issue with symmetric key encryption is delivery of the secret key. The sender needs the key to encrypt but how can the key be securely delivered to the receiver to allow decryption?

In asymmetric key encryption two different keys are used, one for encryption and the other one for decryption. Only one of these is a secret.

If asymmetric encryption is to be used the process is initiated by someone in possession of two keys. One of these is a public key which is sent to anyone who is going to partake in an encrypted communication. The other is a secret private key which is never sent to anyone. Having a means of secure transmission of a secret key is no longer an issue.

The most likely scenario is that the holder of the two keys wishes to receive a transmission. In this case a sender uses the public key to encrypt some plaintext and sends the ciphertext to the receiver. The receiver is now the only person who can decrypt the message because the private and public keys are a matched pair. The public key can be provided to any number of different people allowing the receiver to receive a private message from any of the different people. There are two points to note here.

- If two people require two-way communication, both communicators need a private key and must send the matching public key to the other person.
- There are two requirements to ensure confidentiality should the transmission be intercepted and the message extracted: the encryption algorithm must be complex and the number of bits used to define the key must be large.

Question 21.01

One method used by an unauthorised person attempting to decrypt a message is called a brute-force attack where all possible values for the key are tried. Calculate how long it would take to try all possibilities for a 64-bit or 128-bit key, assuming each attempt took 1 second.

The above account does not completely answer the question of how encryption works. The missing factor is an organisation to provide keys and to ensure their safe delivery to individuals using them. This will be discussed in the next section.

21.02 Digital signatures and digital certificates

Using asymmetric encryption, the decryption–encryption works if the keys are used the other way round. An individual can encrypt a message with a private key and send this to a recipient who has the corresponding public key and who can then use this to decrypt the received ciphertext. This approach would not be used if the content of a message was

confidential because anyone might be in possession of the public key. However, it could be used if it was important to verify who the sender was. Only the sender has the private key and the public key only works with that one specific private key. Therefore, if the recipient finds that the decryption is successful, the message has in effect been received with a digital signature identifying the sender.

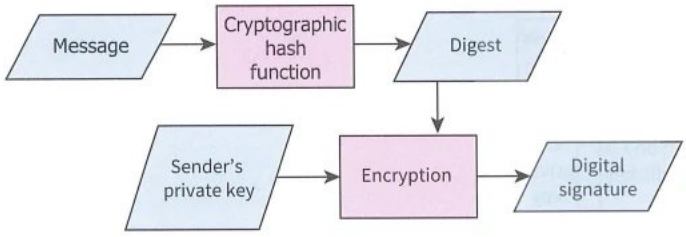


Figure 21.02 Sender using a one-way hash function to send a digital signature

There is a disadvantage in using this method of applying a digital signature: it is associated with an encryption of the whole of a message. An alternative is for the sender to use a public cryptographic one-way hash function which creates a number that is uniquely defined for the particular message, called a 'digest'. The process at the sender's end of the transmission is outlined in Figure 21.02. The private key is used to encrypt the digest. The encrypted digest is the digital signature. The message can be transmitted as plaintext together with the encrypted digest as a separate file. Because the digest is much smaller than the whole message the encryption and the transmission are faster processes than if the whole message were encrypted.

The processes that take place at the receiver end are outlined in Figure 21.03. The same public one-way hash function is used to create a digest from the received message. Then the encrypted version of the original digest is decrypted using the public key.

If the two digests are identical the receiver can be confident that the message is authentic and has been transmitted unaltered.

Note that the digital signature is different each time this process is used. This is because the digest is uniquely defined by the hash function being applied to that particular message.

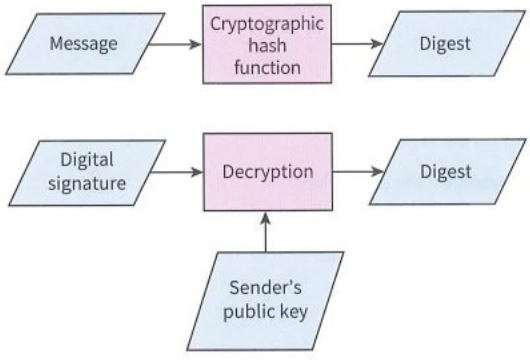


Figure 21.03 Receiver checking that the received transmission is authentic and unchanged

However, the authenticity only confirms to the receiver that the message was sent from the person who had sent them the public key. It does not consider the fact that someone might create a public key and pretend to be someone else.

Therefore, a more strict way of ensuring authentication is needed. This can be provided by a Certification Authority (CA) as part of a Public Key Infrastructure (PKI).

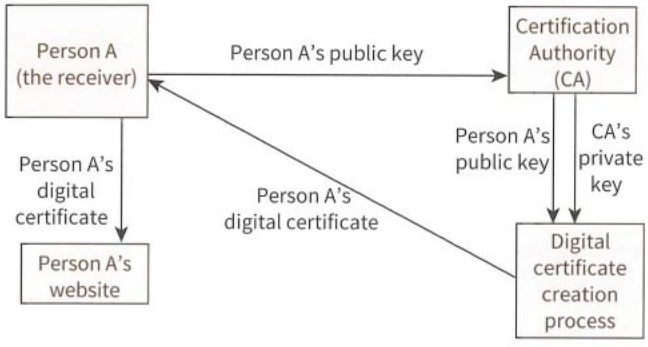


Figure 21.04 Processes involved in obtaining a digital certificate

Let's consider a would-be receiver who has a public–private key pair. The receiver wants to be able to receive secure messages from other individuals, and these individuals want to be confident about the identity of the receiver. The public key must be made available in a way that ensures authentication. The steps taken by the would-be receiver to obtain a digital certificate to allow safe public key delivery are illustrated in Figure 21.04. The process can be summarised as follows.

1. An individual (person A) who is a would-be receiver and has a public–private key pair contacts a local CA.
2. The CA confirms the identity of person A.
3. Person A's public key is given to the CA.
4. The CA creates a public-key certificate (a digital certificate) and writes person A's public key into this document.
5. The CA uses encryption with the CA's private key to add a digital signature to this document.
6. The digital certificate is given to person A.
7. Person A posts the digital certificate on a website.

Figure 21.04 shows person A placing the digital certificate on that person's website but another option is to post it on a website designed specifically for keeping digital certificate data.

Anyone who wishes to extract the public key from the certificate has to use the CA's public key.

For this overall process to work there is a need for standards to be defined regarding the public key infrastructure and the production of the digital certificate. As ever, the name for the standard, X.509, is not very memorable.

TIP

There are two similar processes that have been discussed. In one case someone with a private key sends a public key to someone else. In another case the CA sends a digital certificate containing a public key. Try not to confuse these two.

The following are a few notes to summarise the options available.

- The starting position is someone who has a public–private key pair which are associated with a specific asymmetric key encryption algorithm.
- This person could just make the public key available to anyone who is going to be either a sender or a receiver.
- For optimum security the person instead sends the public key to a Certification Authority.
- The Certification Authority creates a digital certificate which contains the public key with proof of the ownership of the public key.
- Anyone wishing to use the public key obtains it from this digital certificate.
- A message encrypted with the public key could be sent to the owner of the private key.
- A message encrypted with the private key could be sent to anyone having the public key.
- The owner of the private key could use it to create a digital signature that could be used to authenticate an email as was suggested in Chapter 9 (Section 9.03).

21.03 Symmetric key encryption methods

For many years the Data Encryption Standard (DES) was the normal choice for symmetric key encryption. As the weakness of DES became a problem, Triple DES took its place. In 2001 the Advanced Encryption Standard (AES) was introduced as a superior approach. For education purposes only a simplified DES (S-DES) was introduced which allowed the sort of operations performed in encryption to be better understood. The following is an overview of S-DES.

S-DES is an example of a block cipher which means encrypting blocks of bits. In S-DES 8-bit blocks are encrypted. A 10-bit key is chosen. The first stage is to create two 8-bit keys from the 10-bit key. The first step in this first stage is a permutation (reordering of digits) which can be illustrated by the following.

Suppose that the 10-bit key is chosen to be	0101010101
when subjected to a permutation which can be represented by	3 5 2 7 4 10 1 9 8 6
it becomes	0010110011

The numbering of the bit positions is read from left to right so the new 10-bit version has the old position 3 value followed by the old position 5 value and so on. The next step is to apply a circular left shift to the first 5 bits and to the last 5 bits. This produces 0101000111. Finally, the first of the two 8-bit keys to be used in the encryption is created using the permutation 6 3 7 4 8 5 10 9. In our example this key is 00011011. A slightly modified version of this is used to create a second 8-bit key.

The second stage is the encryption, which is a five step process.

1. An initial permutation.
2. Application of a function using the permuted code and the first encryption key.
3. A switch of the first and last 4-bit parts.
4. A repeat application of the function but this time with the second encryption key.
5. A final permutation using the reverse of the initial permutation sequence.

The decryption by the receiver of a transmission uses the same generated 8-bit keys and follows the reverse of the above process.

The AES standard defines the block length as 128 bits. The user can choose to use 128, 192 or 256 bits for the key. The chances of the key being identified from the transmitted ciphertext are small. The main concern is the safety of the method used to provide the key to both sender and receiver.

Extended Question 21.01

Would you like to investigate S-DES further? You could attempt an encryption and decryption.

21.04 Public key encryption methods

RSA (Rivest-Shamir-Adleman), the usual method for public key encryption, is named after the three people who created it. The major features of the method are the key generation algorithm and the encryption function.

The key generation can be summarised as follows.

1. Two very large prime numbers p and q are chosen and their product n is calculated.
2. The product (p-1)(q-1) is calculated.
3. A prime number e less than (p-1)(q-1) and not a factor of it is chosen (65537 is the usual choice).
4. Another number d is found which satisfies the condition that the product of d times e when divided by (p-1)(q-1) gives a remainder of 1.
5. The public key becomes the pair (n,e).
6. The private key becomes the pair (n,d).

The security of the algorithm depends on the fact that finding factors of a very large number is not feasible within any reasonable time scale. Computing n from p and q is straightforward but deducing p and q given n is not!

The encryption works on numbers so a text to be encrypted must first have the characters replaced by numbers according to a sensible coding scheme. If such a number x is to be encrypted as y then y is calculated so that the following relationship holds:

$$y = x^e \bmod n$$

A similar relationship involving d rather than e is used for decryption.

Public key encryption is inherently more secure than symmetric key encryption but the algorithms are not as fast. It is quite common for public key encryption to be used to deliver securely a key that can then be used for symmetric key encryption.

21.05 SSL and TLS

When we access a website, we have two concerns. The first is whether or not the website is genuine. The second is whether we can transfer sensitive personal data to the website, for example to buy a product offered for sale on the website. The Secure Socket Layer (SSL) protocol was created to give assurance to a website user when a client–server application is underway. As described in Chapter 17 (Section 17.04), the interface between an application and TCP uses a port number. In the absence of a security protocol, TCP services an application using the port number. The combination of an IP address and a port number is called a 'socket'. When the Secure Socket Layer protocol is implemented it functions as an additional layer between TCP in the transport layer and the application layer. When the SSL protocol is in place, the application protocol HTTP becomes HTTPS.